

Aegis threat model

Assets and trust boundaries

Assets are provider keys, policy integrity, user-supplied sensitive data, generated answers, and correctness of evaluation evidence. Untrusted input includes user text, search queries, and retrieved text. The repository, server environment, and checked-in policy manifest are trusted. Compromise of those roots defeats the source hash check.

The application is a public fictional-bank demo with no transaction tools. It cannot move funds, fetch real customer records, or modify an account.

Controls

Threat	Control	Remaining limitation
Prompt injection / jailbreak	Normalized patterns plus Moss threat matching	Novel or multilingual attacks may evade both
Poisoned retrieved context	Exact ID + SHA-256 match to approved corpus	A compromised manifest is outside this boundary
Unsupported output	Source re-retrieval plus numeric membership checks	Similarity is not entailment; relationships can still be wrong
PII leakage in candidate	Output scan; rejected candidate omitted from trace	Heuristics do not identify every possible personal datum
PII in trace	Redaction before retention; no external raw-prompt trace ingestion	Redaction is not a full DLP system
Cross-user trace access	Session cookie partition and scoped search	No authenticated multi-tenant accounts
Global demo disruption	Simulations scoped to one request	Shared compute still has finite capacity
Provider outage	One optional generation backup, bounded waiting, explicit unavailable outcome if both fail	Backup can also fail; native retrieval operations may continue after caller timeout
Credential leakage	Keys remain server-side; fixed provider URLs; redirects rejected; API-key patterns blocked/redacted	Pattern-based detection is not comprehensive secret classification

Threat	Control	Remaining limitation
Eval overclaim	Separate safety/usefulness criteria and explicit missing evidence failures	Public suite is small and used during development
Cost abuse	Body limits and separate per-instance rate limits	Requires distributed controls for production scale

Privacy and retention

Session cookies are HttpOnly, SameSite=Strict, and Secure in production. Memory contains at most 50 redacted traces per session and 200 sessions per process; traces expire after one hour. Memory can disappear on cold starts. Exports are user-controlled copies. Evaluation history uses browser localStorage and contains only the fixed public cases.

No rejected candidate answer is persisted. Diagnostic API errors are generic. Credentials remain in server environment variables and are ignored by Git.

The configured generation provider receives the fictional policy context and user question after input/context gates pass. When backup generation is enabled, the second provider receives that same content after a primary generation failure. Error bodies are discarded; receipts contain only provider identity, timing, status codes, and reported usage. Rejected output never triggers another provider attempt.

Tested failure cases

Unit coverage includes ungrounded output withholding, numerical hallucination despite high similarity, source-ID forgery, failed generation, isolated outage simulation, missing-evidence grading, session isolation, expiration, and identifier redaction. Browser tests exercise actual provider calls, all demo scenarios, exports, mobile overflow, accessibility checks, malformed inputs, and visitor isolation.

Claims deliberately not made

Universal injection prevention; formal fact verification; signed/tamper-proof receipts; durable distributed logs; distributed abuse protection; independent benchmark performance; or suitability for real banking without substantial further controls.